

Information Security Management Systems

Jorge Blasco Alis

Adapted for Seguridad de la Información (UPM-ETSISI)



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON

Reminder...



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON

Security Goals

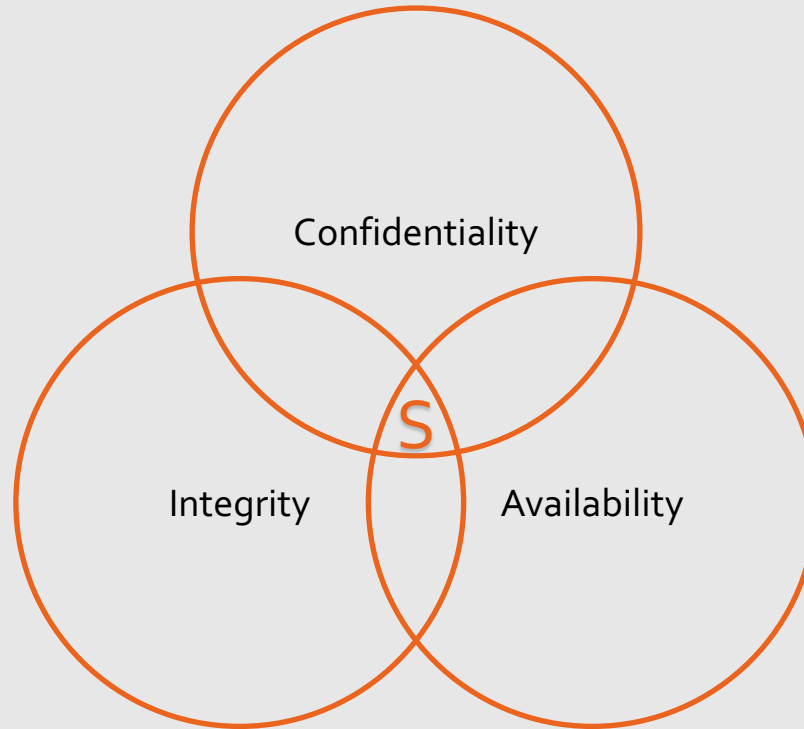


- Confidentiality
 - + Information can only be read by authorised parties
 - Prevention of unauthorised information release
- Integrity
 - + Information can only be modified by authorised parties
 - Prevention of unauthorised information modification
- Availability
 - + Information can accessed when needed
 - Prevention of unauthorised denial of use

The CIA Triad



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON





- CIA are useful but on their own they mean nothing
- What does the CIA mean for a business?
 - What should we keep confidential? How?
 - How ensure the integrity of our information and systems?
 - How we make sure our services remain available? Even after a breach?

We must always analyse CIA in the context of the business needs

Information Security Management



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON



What is Information Security Management?

What is Information Security Management?



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON

- Not very easy to answer
- Information Security Management has a very broad scope
- **All the aspects of making security happen in an organisation**



Information security management is about creating a risk-managed environment so the organisation can focus on achieving its business goals.



Because the environment involves the organisation, ISM needs to be traversal to the whole organisation and will impact all units within the organisation



What is an Information Security Management System (ISMS)?



The system (policies, processes, controls, etc.) put in place to achieve that risk-managed environment



Who is in charge of Information Security
Management?

Who is in charge of ISM?



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON

Chief Information Security Officer (CISO)



How do we implement an Information Security Management System (ISMS)?



Normally via standards

Why Standards?



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON

What is a standard?



A

Process which supports an approach to a specific objective

B

Binding legislative act

C

An agreed way of doing something

D

Guidelines that describe an optimal way of doing things

What is a standard?



Standard

An agreed way of doing something

- 2 main categories
 - De facto
 - Widely used in specific area but no officially recognised
 - Moodle, Office
 - De jure
 - Officially endorsed by a body/government

Who produces standards?



A

Private companies

B

Consortiums

C

Standardisation body

D

Government

Who produces standards?



B

Consortiums

C

Standardisation body

Examples



- Google Cloud
- Amazon AWS
- Dropbox

ISO/IEC 27000 Series



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON



- ISO/IEC 27000 series published by ISO and IEC
- The 27000-series are produced by Subcommittee 27
 - SC 27 is a joint committee which produces security standards
- ISO is made up of national standards bodies
 - AENOR (Spain)
 - ANSI (US)
 - BSI (UK)
 - DIN (Germany)
 - JISC (Japan) ...



- ISO/IEC 27000 series dominates today's world as the basis for performing ISM
- The series provides a range of material, including
 - Definitions of basic terminology
 - Descriptions of how to establish and operate an ISMS
 - Detailed guidance on security controls and also on measuring their effectiveness
 - Detailed guidance on risk assessment and security audit
 - Sector-specific supplements.

Structure



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON

Definitions

27000

Structure



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON

Definitions

27000

Requirements

27001

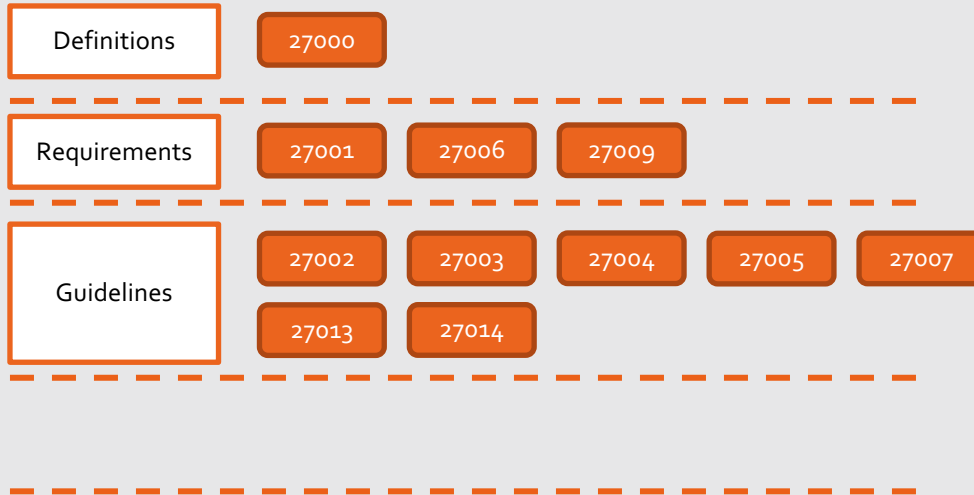
27006

27009

Structure



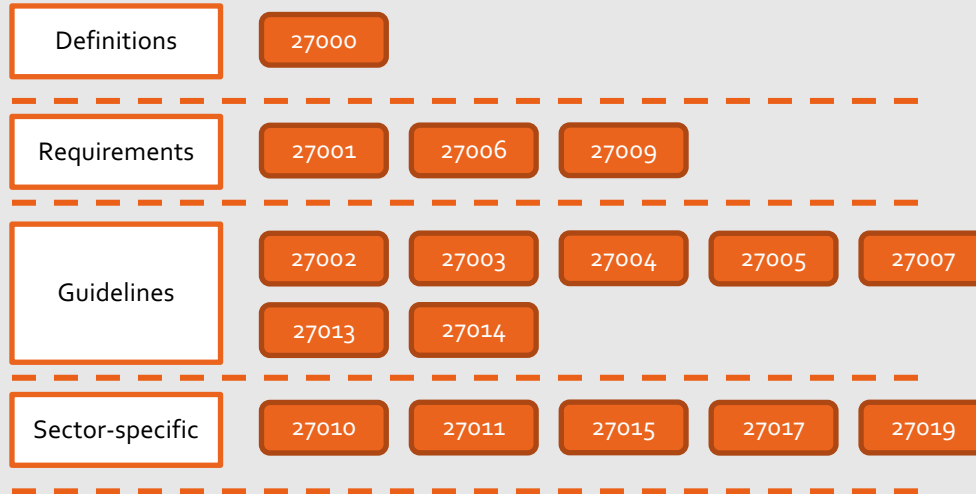
ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON



Structure



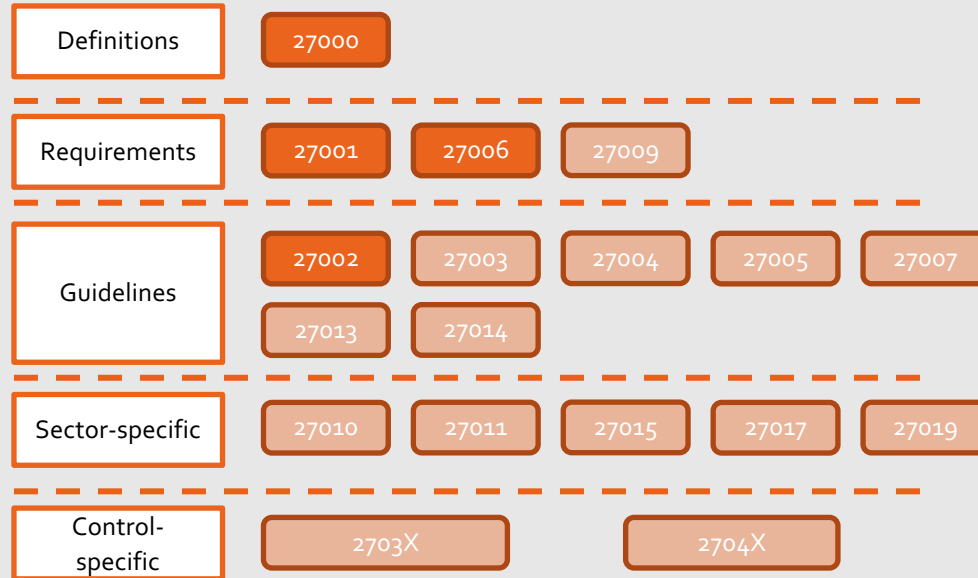
ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON



Structure



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON



ISO/IEC 27000



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON



- The title of ISO/IEC 27000 is **Information security management systems – Overview and vocabulary.**
- It sets remainder of 27000 series in context.
- It has three main parts
 - Definitions of fundamental ISMS terms
 - Description of what constitutes an ISMS
 - Description of each of the members of the ISO/IEC 27000 family

What constitutes an ISMS?



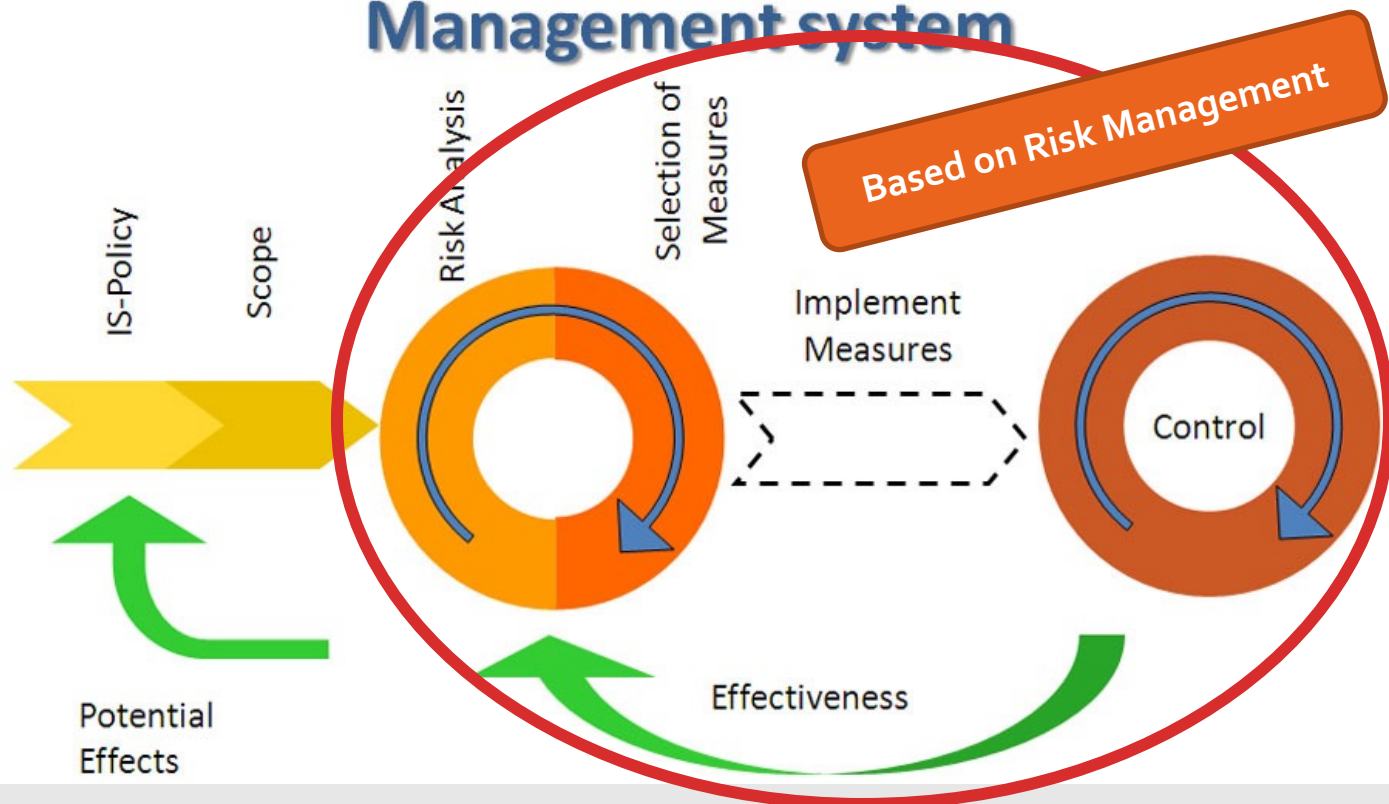
ISMS

Policies, processes, controls, etc. put in place to achieve that risk-managed environment

- Systematic approach to

Establish	Implement
Operate	Monitor
Review	Maintain
Improve	

ISO 27001 Information Security Management system





- Awareness of need for information security
- Assigning responsibility for information security
- Getting senior management commitment
- Risk assessments determining appropriate controls
- Security an essential element of information systems
- Active prevention/detection of security incidents
- Continual reassessment

ISO/IEC 27001



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON

27000 and 27001



- ISO/IEC 27000 is descriptive
 - Describes the context and establishes terminology
- ISO/IEC 27001 is definitive
 - Sets down standardised requirements
- The language used in ISO/IEC 27001 is quite different
 - It uses 'shall'
- This allows organisations to claim compliance to ISO/IEC 27001 (and be audited against it)





- It contains seven main clauses (sections)
 4. Context of the organisation
 5. Leadership
 6. Planning
 7. Support
 8. Operation
 9. Performance evaluation
 10. Improvement

Clause 4: Context



The organisation shall determine

- Interested parties relevant to the ISMS
- Requirements of these interested parties
 - Legal and regulatory
 - Contractual obligations

Why?

- The boundaries and applicability of the ISMS

- The co

The organisation shall establish, implement, maintain and continually improve an ISMS, in accordance with the requirements of this International Standard

Example



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON

- Dropbox Certificate

Clause 5: Leadership



Top management shall

- Demonstrate commitment with respect to the ISMS
 - a) Ensuring information security objectives are set and are compatible with the strategic direction
 - b) Ensuring resources needed for the ISMS are available
- Ensure that the responsibilities and authorities for roles relevant to information security are assigned and communicated

Clause 5: Leadership



Top management shall

- Establish an information security policy
 - a) Is appropriate to the purpose of the organisation
 - b) Includes information security objectives
 - c) includes a commitment to satisfy applicable requirements related to security
 - d) Includes a commitment to continual improvement of the ISMS
- The information security policy shall
 - a) be available as documented information;
 - b) be communicated within the organisation; and
 - c) be available to interested parties, as appropriate

Why?



- Princeton University

Clause 6: Planning



The organisation shall plan

- Actions to address risks and opportunities
 - Define and apply an **information security risk assessment** process
- How to implement the actions into its ISMS processes
 - Define an **information security risk treatment** process
- How to evaluate the effectiveness of these actions
 - Risk monitoring and review

Risk Treatment: Controls



The organisation shall

- Determine controls necessary to implement the chosen risk treatment options
 - Organisations can design controls as required
- Compare the controls determined in step above with those in ISO/IEC 27002
 - Verify no necessary controls have been omitted
- Produce a **Statement of Applicability** containing justifications for both inclusions and exclusions of ISO/IEC 27002 controls

Examples



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON

- Microsoft

Security Objectives



The organisation shall

- Establish information security objectives:
 - Consistent with information security policy
 - Be measurable (if practicable)
 - Take into account applicable information security requirements, and results from risk assessment and risk treatment
 - Be communicated
 - Be updated as appropriate
- The organisation shall retain documentation on the information security objectives

Clause 7: Support



The organisation shall

- The organisation shall provide the resources needed for the ISMS
- Ensure persons have appropriate education, training, or experience
- Ensure persons are aware of the information security policy and the implications of not conforming with the ISMS requirements
- Determine the need for internal and external communications relevant to the ISMS
- Generate documentation required by ISO/IEC 27001

Resources

Competence

Awareness

Communication

Documentation

Clause 8: Operation



The organisation shall

- Plan and control the processes needed to meet security requirements
- Perform security risk assessments at planned intervals **or when significant changes are proposed or occur**
- Implement the information security risk treatment plan
- Retain documented information of the results of the information security risk assessment and treatment

Clause 9: Performance evaluation



The organisation shall

- Evaluate the effectiveness of the ISMS
- Conduct internal audits at planned intervals to check
 - ISMS conforms to the organisation's own requirements for its ISMS and the requirements of ISO/IEC 27001
- Regularly review the ISMS to ensure its continuing suitability, adequacy and effectiveness
- Retain documentation of all these aspects

Clause 10: Improvement



- When a nonconformity occurs, organisation shall:
 - react to the nonconformity, and, as applicable:
 - Take action to control and correct it
 - Deal with the consequences
- Make changes to the ISMS, if necessary
- Shall continually improve the suitability, adequacy and effectiveness of the ISMS

Concluding remarks



- ISO/IEC 27001 is the key ISMS standard.
- Its provisions are therefore of key importance.
- Much of the content is arguably 'obvious'!
- It is potentially hugely helpful to have this 'best practice' encoded in such a way that organisations can be assessed for their compliance with best practice
- The major shortcoming is that it does not prevent companies doing 'just enough' to comply

Toolkits/templates I



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON

The screenshot shows a web browser displaying the CertiKit website. The URL in the address bar is certikit.com/products/iso-27001-toolkit. The page has a teal header with the CertiKit logo (a yellow checkmark in a square) and the tagline "Standards made easy". Navigation links include "Products", "Support", "About", "Testimonials", "Blog", "FAQs", and "Contact". A "Login / Register" link and a yellow "Get in touch" button are also present. The main content area has an orange background and features the title "ISO 27001 Toolkit". The text describes the toolkit as the best way to implement an Information Security Management System (ISMS) to ISO 27001, highlighting the inclusion of 12 months of updates and support. It encourages users to view sample documents, download examples, watch an introductory video, and get instant access. The price is listed as "Only £695.00 Excl. VAT" with a currency selector set to the UK flag. A red "BUY NOW" button is prominently displayed. To the right, there is an illustration of a spiral-bound notebook with a yellow cover labeled "ISO/IEC 27001", and three white document pages labeled "PROCEDURES", "POLICIES", and "CONTROLS".

← → ↺ 🏠 | certikit.com/products/iso-27001-toolkit | 📖 ☆ | ☰ ✍️ ➦ ...

CERTIKIT
Standards made easy

Login / Register

Get in touch

🏠 Products Support About Testimonials Blog FAQs Contact

ISO 27001 Toolkit

The CertiKit ISO27001 Toolkit is the best way to put an Information Security Management System (ISMS) in place quickly and effectively and achieve certification to the ISO27001 standard with much less effort than doing it all yourself. Our quality template documents and checklists come complete with 12 months of updates and support, helping you to get to ISO27001 certification fast. Below you can see what's in the Toolkit, view sample documents, download examples, watch our introductory video, and get instant access to your toolkit with a choice of currencies and payment options.

Only
£695.00  **BUY NOW**

Excl. VAT

Toolkits/templates II



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON

← → ↻ 🏠 | infosecurity-magazine.com/news/new-version-of-isoiec-27001-templates-now

infosecurity GROUP MAGAZINE EVENTS LEADERS NETWORK INSIGHT

Subscribe to Infosecurity Magazine Strategy - Insight - Technology [Subscribe now](#)

Sign Up Log In

f t g+ in

info security Latest Patching Problems, but is Runtime an Attractive Solution

STRATEGY | INSIGHT | TECHNOLOGY

🏠 News Topics Features Webinars White Papers Events & Conferences Directory 🔍

INFOSECURITY MAGAZINE HOME » NEWS » NEW VERSION OF ISO/IEC 27001 TEMPLATES NOW AVAILABLE

16 OCT 2013 NEWS

New Version of ISO/IEC 27001 Templates Now Available

Our website uses cookies
Cookies enable us to provide the best experience possible and help us

The new version from Public IT includes 17 brand-new documents and builds on the experience of its customers in implementing the ISO/IEC 27001 standard, starting from a comprehensive, pre-written information security management system (ISMS).

The **document template set** includes all of the policies, plans, processes and procedures required by the information security standard, together with guidance notes for their implementation. The structure of the ISMS and the headings within each document map directly onto the standard and mean that, in many

 **Latest Industry White Papers**
[Download now](#)

Examples



- Google Cloud
- Amazon AWS
- Dropbox
- EY Register

Certification



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON



ISO/IEC 27002



ROYAL
HOLLOWAY
UNIVERSITY
OF LONDON



- The title of ISO/IEC 27002 is **Code of practice for information security controls**.
- Provides a catalogue of state of the art security controls
 - Examined later in the course
- ISO/IEC 27001 requires them all to be considered for use as part of an ISMS, and reasons given for excluding any
 - **Statement of Applicability**



- Guidance on security policies Are security policies controls?
- List of 35 **control objectives**
 - under each control objective, a number of specific **controls** to achieve the objective
 - under each control, **implementation guidance** and **other information** relevant to that control.

What is a security control?



Security Control

Measure that modifies risk.

- Controls are used to meet the security objectives
- Security controls include
 - Security policies
 - Processes
 - Devices and technology
 - Practices